

Guía metodológica de la Encuesta TLPT / DORA / TIBER-ES

1. Objetivo y alcance

Esta guía describe el uso de la encuesta para evaluar el grado de implantación, calidad y eficacia de las pruebas TLPT en entidades financieras y proveedores TIC relevantes bajo DORA y TIBER-ES.[web:16]
[web:38]

El propósito es doble: (i) construir una visión comparativa a nivel nacional/sectorial; (ii) apoyar a cada entidad en el diseño de su propia hoja de ruta de ciberresiliencia.

2. Población objetivo

- Entidades sujetas a DORA con probabilidad razonable de ser designadas para TLPT (G-SII/O-SII, infraestructuras de mercado, entidades significativas).[web:31]
- Proveedores TIC críticos o importantes para dichas entidades, especialmente cuando participen en pruebas conjuntas o pooled TLPT.[web:39]

3. Estructura de la encuesta

La encuesta se articula en 8 bloques:

1. Datos generales de la organización.
2. Gobierno y alineamiento normativo.
3. Alcance, criticidad y dependencia de terceros.
4. Metodología TLPT, TTI y Red Team.
5. Detección, respuesta y continuidad.
6. Hallazgos, remediación y attestation.
7. Frecuencia, planificación y madurez cultural.
8. Preguntas abiertas para contexto cualitativo.

Cada bloque puede puntuarse en una escala 0–100 para obtener un Índice Global de Madurez (IGM).

4. Lógica de puntuación (IGM)

4.1 Enfoque general

- Cada pregunta cerrada tiene opciones que se mapean a puntuaciones ordinales (p. ej., 0–3).[web:39]
- Las preguntas se agrupan por dominio (Gobierno, Alcance, Metodología, Operaciones, Remediación, Cultura).
- El IGM se calcula como promedio ponderado de los dominios, donde las dimensiones operativas (detección, respuesta, remediación) suelen tener mayor peso que las puramente documentales.

4.2 Ejemplo de asignación de puntos

- Preguntas de madurez (p. ej., existencia de política TLPT):
- Opción mínima (sin política/solo intención): 0 puntos.

- Menciona TLPT sin formalización clara: 1 punto.
- Política formal aprobada: 2 puntos.
- Política + proceso + revisión periódica: 3 puntos.
- Preguntas de cumplimiento de referencia de RTS/TIBER-ES (p. ej., duración de Red Team ≥ 12 semanas):
- Práctica muy por debajo de la referencia: 0 puntos.
- Parcialmente alineada: 1 punto.
- Alineada: 2 puntos.
- Alineada y superando requisitos mínimos: 3 puntos.[web:16][web:34]

Política + proceso + revisión periódica: 3 puntos.

Preguntas de cumplimiento de referencia de RTS/TIBER-ES (p. ej., duración de Red Team ≥ 12 semanas):

Luego se normaliza 0–3 – 0–100 por dominio y se calculan ponderaciones.

5. Uso analítico

- Comparar entidades entre sí (benchmarking sectorial), respetando la confidencialidad.
- Seguir la evolución de una entidad en el tiempo (línea base vs. siguiente ciclo de TLPT).
- Correlacionar niveles de madurez (IGM) con indicadores duros de incidentes, pérdidas y sanciones.

6. Limitaciones y buenas prácticas

- La encuesta no sustituye al informe TLPT ni a los requisitos formales de información a supervisores.
[web:16]
- La autodeclaración tiende al optimismo; se recomienda acompañar resultados con evidencia (políticas, informes, actas de comités).
- Conviene realizar sesiones de calibración (workshops) para que todas las entidades interpreten las preguntas de forma homogénea.

7. Recomendaciones para la aplicación

- Aplicar la encuesta antes del TLPT para diseñar el alcance y, de nuevo, después del cierre para medir el salto de madurez.
- Integrarla en los procesos de revisión anual de riesgos y planes de resiliencia digital (marco DORA).
[web:26]
- Fomentar respuestas conjuntas CISO–riesgos–negocio para evitar visiones parciales (y peleas de pasillo posteriores).

8. Custodia y confidencialidad

- Los resultados deben tratarse como información sensible de ciberseguridad.
- Cualquier uso agregado para informes públicos se realizará con anonimización y agregación adecuada.
- Si se comparte con supervisores, conviene anexar contexto y explicar decisiones de interpretación.